PROPOSAL IMPLEMENTATION AND MIGRATION ASSURANCE

API3 DAO migration audit

Final report | Codex review

Prepared by: API3 leadership team

Version: 1.5

Review dates: 26-29 October 2026

Report date: 29 October 2026

Assessment status: Complete. AUD-02 and AUD-03 mitigated. AUD-04 resolved. AUD-01 accepted.

Review target: api3dao/api3-dao-migration-proposal

Source revision:
`c7a7d26c705f703ff50b80e8f976ab3dcdee1372`

Reference network: Ethereum mainnet, chain ID 1

Reference block: 26,296,196

Conclusion: review complete for the stated source revision.

The tested migration path succeeds. All four findings and their history are retained. AUD-02 is mitigated by removing the primary's dependency on PNK and wPOKT transfers. AUD-01 remains an accepted risk. Remaining asset-balance and transfer-availability checks are execution preconditions. AUD-03 is mitigated by the explicit build-block verification fallback, with authenticated generation records still required. AUD-04 is resolved by the committed title, authenticated IPFS description, and final metadata review.

This report assesses the source revision and reference state identified above. It records tested mitigation, acknowledged risks, and the operating requirements for preparing and executing the proposal. Verification of the actual posted vote is a separate release step. No mainnet transaction was signed or broadcast during the review.

1. Executive conclusion

The reviewed implementation builds one primary Aragon CallsScript containing 26 calls. Posted secondary votes 133 and 134 separately transfer PNK and wPOKT to the Agent Safe. On its intended path, execution transfers the listed treasury assets, makes the one-time API3 mint, removes the pool and primary Agent from the minter set, transfers token ownership to the dead address, disables new legacy proposals, and removes selected root permissions.

The current repository has 20 tests. Together with 12 retained audit and compatibility checks and nine retained secondary-split checks, all 41 tests pass at both the original block 26,287,968 and the final reference block 26,296,196. Nine duplicated legacy tests were removed and one exact-amount serialization test was added since the previous report. Their substantive assertions remain covered by the current tree suites. Coverage includes all six execution orders, generation after emptying both secondary tokens, exact secondary payloads, and primary independence from reverting token contracts. Passing observation tests confirm recorded behavior and do not resolve accepted findings.

The migration moves governance to Snapshot and preserves the staking mechanisms intended to supply voting power there. AUD-01 concerns the execution authority of Aragon proposals created before migration. In simulation, one such proposal obtains approval afterward and changes a pool exit parameter through surviving Agent permissions. The outstanding-proposal review is complete. The proposal author confirms that no unrelated existing proposal can affect the migration outcome. The remaining accepted risk concerns a new competing proposal created before primary execution. Designated token-transfer secondaries 133 and 134 are intentional parts of the migration. The demonstrated contract authority remains in place.

AUD-02 is mitigated in commit `c6d977f`, merged as `a920489`, for the primary's dependency on PNK and wPOKT. PNK and wPOKT reads, nonzero-balance requirements, and transfers are removed from the primary. Their token restrictions can therefore no longer block primary generation or execution. The remaining primary API3, USDC, and ETH transfers use fixed amounts. Later deposits alone do not prevent execution and are accepted without an automatic sweeping requirement. Balance sufficiency and USDC transfer availability remain execution preconditions. The separate token proposals retain their own transfer risks. AUD-03 is mitigated by the build-block fallback in `7b14436`, merged as `4740c29`. Seventeen CLI scenarios exercise the real verifier on locally posted votes. Generation-block hash and artifact authentication remain operating requirements. AUD-04 is resolved in this version by review of the final committed metadata and its authenticated IPFS document.

The proposal author confirmed that 200,000,000 API3 is a target subject to holders burning tokens and to an explicit cleanup burn by a DAO Safe if additional rewards are minted before execution. Commit `6596a81` clarifies the earlier Treasury-specific cleanup assumption: the responsible DAO Safe is an operator choice. The Treasury Safe remains the fork-test example and opts out of burner status afterward. Supply drift is therefore documented as an acknowledged design condition rather than a separate defect requiring exact supply at atomic execution.

Final dispositions and execution conditions

AUD-02 has a tested mitigation: the primary no longer calls or reads PNK or wPOKT. AUD-01 remains an accepted design risk. AUD-03 now has a tested build-block fallback. Its remaining provenance requirements and the resolved AUD-04 history are recorded in section 4. Original severities, acknowledgments, and technical evidence are retained. Fixed-amount asset handling and later donations are accepted design conditions.

This completes the review of the identified revision. Proposal preparation and execution must follow section 7, including verification against the approved generation state, complete voter-facing metadata, and fresh execution precondition checks. Source or metadata changes are assessed under the revision protocol in Appendix C.

2. Scope and review boundaries

Subject of the review

Version 1.5 reviews all 15 changed in-scope files since `4740c29`. Changes cover final metadata, exact monetary serialization, duplicated-test removal, burner cleanup, and source and README commentary. Executable migration, interface, and verifier logic are unchanged. Original-block regeneration reproduces the previous 26-call payload. The final-reference mint reflects the weekly reward already minted. Appendix B binds both payloads and final metadata.

The existing Aragon DAO, API3 token, and staking pool are inspected only to establish migration preconditions, interface behavior, authority relationships, and post-migration compatibility. Existing behavior is reported as a finding only when it prevents the proposal from satisfying its stated migration requirements or undermines its preparation and verification workflow.

In scope	Review purpose
`src/MigrationScript.sol` and `src/Interfaces.sol`	Call order, callers, destinations, amounts, minting retirement, transition of governance to Snapshot
`script/CreateVote.s.sol` and `script/VerifyVote.s.sol`	Payload generation, metadata construction, generation provenance, posted-vote verification
`proposal/title.txt` and `proposal/description.md`	Exact metadata committed by the proposal
`scripts/*.mjs` and `scripts/pick-voters.sh`	Decoding, README consistency, voter-fixture preparation
`test/`, `foundry.toml`, setup and test scripts, CI, README	Assertions, execution paths, reproducibility, documented claims
Existing DAO dependencies at the reference block	Necessary integration behavior and preconditions for this migration
Posted secondary votes 133 and 134	Exact transfer scripts, recipients, amounts, immutable descriptions, and interaction with primary execution

Exclusions

Other repositories, Snapshot configuration, voting strategies and delegation rules, future governance execution, Safe operations and key custody, replacement governance implementations, and the complete TimelockManager implementation are external dependencies. Their readiness effects are recorded as assumptions.

The final proposal PDF is assessed for correspondence with migration actions and operating assumptions. Its legal terms, commercial and market claims, business forecasts, historical incident statistics, and historical vesting-bypass investigation remain author-supplied context outside this assessment.

This work uses source review, read-only chain calls, and synthetic local forks. It does not assess unrelated live applications or claim that a competing vote used in a test exists on mainnet.

Review identity and independence

The report is prepared by the API3 leadership team using source inspection, public explorer references, Foundry, and Codex-assisted analysis and test orchestration. It is an internal technical assessment. It does not represent independent assurance or an attestation by an external auditing firm.

3. Intended transition and acceptance criteria

The intended future behavior is governance through Snapshot, permanent termination of API3 minting, and continued operation of staking-pool user actions without new minted rewards. New proposals are disabled on the legacy Aragon voting apps. Staking-based voting power is intended to remain usable in Snapshot, subject to its external configuration. Remaining Aragon proposal authority and treasury balance-change risks are acknowledged and accepted as described in section 4.

ID	Acceptance criterion	Assessment of reviewed revision
GOV-1	New proposals cannot be created on either legacy voting app through any public creation route	Pass in tested fork paths
GOV-2	Remaining execution authority of pre-migration Aragon proposals is identified and its migration risk is expressly accepted or eliminated	Accepted risk, AUD-01. Outstanding-proposal review complete. Residual risk concerns new competing proposals before primary execution
GOV-3	Staking-based voting power remains available for the intended Snapshot governance system	Pool stake/share accounting and delegation remain operational in tested flows. Snapshot configuration is an external dependency
TOK-1	The pool and primary Agent cannot mint after execution	Pass at the reference state
TOK-2	No other active minter survives and minting cannot be reauthorized	Historical reference evidence supports the known minter set. Final execution preflight remains required
SUP-1	Supply targets 200M API3 with acknowledged burns and documented overshoot cleanup	Conditional, acknowledged target. Operator cleanup remains external
AST-1	Primary API3, USDC, and ETH transfers reach the intended Safes. PNK and wPOKT move through designated secondaries	Pass in tested paths without intervening drift. All six execution orders pass. PNK/wPOKT dependency mitigated under AUD-02. Fixed-amount execution checks remain in section 7
POOL-1	Existing balances, stake, shares, reward locks, and exit rights survive migration	Pass for tested migration flows. Continued authority of older Aragon proposals is separately accepted under AUD-01
POOL-2	Deposits, staking, unstaking, withdrawals, delegation, and pool-side vesting interfaces remain usable	Pass in the covered scenarios. Manager-side execution is excluded
META-1	The final voter-facing text is complete and corresponds to the exact payload	Pass for the committed title and authenticated IPFS description. AUD-04 resolved
VER-1	A correctly generated posted proposal can be independently matched to its reviewed source and generation state	Mitigated under AUD-03 through the build-block overload. Snapshot guards and authenticated generation records remain required

Migration architecture and authority

Calls	Action	Required caller
1-2	Give the primary Agent transfer and execution access to the secondary Agent	Primary voting app calls ACL
3-4	Move secondary Agent USDC and ETH to the Agent Safe	Primary Agent, then secondary Agent
5	Move the primary Agent's API3 to the Treasury Safe	Primary voting app calls primary Agent
6-10	Remove pool minting, temporarily enable the primary Agent, mint to the Treasury Safe, disable Agent minting, transfer ownership	Primary Agent as token owner
11-14	Revoke wildcard vote creation and remove its managers	Primary voting app calls ACL
15-22	Raise support and quorum on both apps, remove their managers	Primary Agent changes settings, voting app removes managers
23-26	Revoke Kernel app-management and ACL permission-creation roles and remove managers	Primary voting app calls ACL

CallsScript execution is atomic. A failing call rolls back the proposal's execution. The fixed list of treasury balances and the fixed mint amount are read when the script is generated. They are not recomputed by the script at execution.

Posted secondary proposals and execution order

Both secondary votes were open and unexecuted at final reference block 26,296,196. Their scripts, metadata, creators, and stored thresholds match the original capture. Their exact on-chain scripts were decoded and compared byte for byte with the intended transfers. Each script has one CallsScript entry calling the secondary Agent's `execute`, which calls the relevant token's `transfer` with zero ETH value. Both recipients are the Agent Safe `0xbbe0de9757f93e3306adbfebe906ab285edd13da`.

Secondary vote	Encoded transfer	Creation block	Observed status
133	1,547,987 PNK	26,285,795	Open, unexecuted
134	249,999.99 wPOKT	26,285,961	Open, unexecuted

The encoded base-unit amounts are `1547987000000000000000000` for PNK and `249999990000` for wPOKT.

Creation transactions are vote 133 and vote 134. The creators are distinct from one another and from the Vault Safe intended to post the primary. The Vault's observed cooldown and snapshot voting power permit proposing at the reference state. Eligibility must be checked again at submission.

The descriptions linked in the creation events were retrieved and their bytes verified against their raw SHA-256 IPFS CIDs. The PNK description and wPOKT description accurately specify the token, recipient, and encoded amount. Both describe a later sale for USDC by the Agent Safe. That sale is a separate operator action and is not encoded or assured by these proposals.

Secondary execution and retry risk

Secondary-first execution is the operational expectation. Successful execution supports any order: all six permutations were tested successfully on a local fork with simulated holder approvals, including the primary executing first and either secondary executing afterward. The existing secondaries retain their stored support and quorum and the secondary Agent execution permission after migration.

Anyone can execute an approved vote, and no execution order is enforced or required. Votes 133 and 134 close on 3 November 2026 at 18:18:47 and 18:51:59 UTC respectively. Early execution requires strictly more than 50% of total snapshot voting power voting yes. At close, each needs more than 50% support among votes cast and more than 15% of total snapshot voting power voting yes. Passage and token transfer availability remain necessary in every order. If the primary executes before both secondaries have passed, a failed secondary cannot be replaced because new proposal creation is disabled. An unusable secondary payload also cannot be replaced after primary execution. The proposal author accepts this retry risk.

Authority retained by the reviewed script

The following permissions explain how Aragon proposals created before migration can retain execution authority after new proposal creation is disabled. The reference ACL history identifies the original grants and managers. The script leaves the listed paths in place or adds them during migration. Added local post-state checks confirm the key Agent and registry permissions described by the accepted finding AUD-01.

Authority holder	Remaining permission or relationship
Primary voting app	Primary Agent execution, script-running, and transfer roles, with the primary voting app retaining their managers
Secondary voting app	Secondary Agent execution, script-running, and transfer roles, managed by the primary voting app
Primary Agent	Newly granted execution and transfer roles on the secondary Agent
Primary Agent	Support and quorum modification roles on both voting apps. The migration removes their managers but retains the role grants
Primary voting app	Script-registry executor-addition and registry-management permissions, with their managers retained

The migration removes the primary voting app's Kernel app-management and ACL permission-creation grants and their managers. Those removals do not erase other existing grants. The proposal author's acceptance of AUD-01 includes the surviving relationships described here.

4. Findings and final dispositions

Severity model

Severity combines impact on the migration's stated requirements and the conditions needed for the effect to occur. High denotes a material failure of authority retirement or protection of user funds or exit rights. Medium denotes a material preparation, verification, execution, or asset-completeness failure under plausible state changes. Low denotes a limited defect that still needs correction or an explicit readiness decision. Critical would require an immediate or broadly reachable catastrophic outcome. No critical finding was confirmed in this review.

The governance finding requires a previously created legacy proposal and sufficient approval under its original thresholds. It is not a claim of permissionless control by an arbitrary account.

The dispositions distinguish the tested mitigations of AUD-02 and AUD-03 from accepted risks and release requirements. Original acknowledgments remain in the finding history. Technical mitigation is supported by the identified source change and retest.

Finding	Severity	Disposition	Remaining effect or requirement
AUD-01: Pre-migration Aragon proposals retain execution authority	High	ACK, risk accepted	Outstanding-proposal review complete. No unrelated existing proposal affects migration. Risk of new competing proposals before execution accepted
AUD-02: Primary execution depended on PNK and wPOKT	Medium	Mitigated	PNK and wPOKT removed from the primary. Separate balance and transfer-availability preconditions remain
AUD-03: Snapshot reconstruction can reject unchanged payloads	Medium	Mitigated	Explicit build-block fallback tested. Retain block hash and artifact provenance. Snapshot amount guards still apply
AUD-04: Proposal description was a placeholder	Low, original	Resolved	Final committed title and IPFS content reviewed. Posted-event comparison remains an operational step

Finding history

Finding	Affected revision	Disposition or remediation	Retest result
AUD-01	`0e10333`	ACK, risk accepted	Reproduced, no technical fix
AUD-02	`0e10333`	ACK, risk accepted	Original observations retained
AUD-02	`c6d977f` / `a920489`	PNK/wPOKT isolated, 28 October	9 targeted checks and 49 fork tests pass
AUD-03	`0e10333`	ACK, now superseded	Original snapshot limitation retained
AUD-03	`7b14436` / `4740c29`	Build-block fallback, 28 October	17 CLI scenarios and 49 fork tests pass
AUD-04	`0e10333`	ACK, now superseded	Original placeholder observation retained
AUD-04	`5bff6fc` / `c7a7d26`	Final metadata supplied, 29 October	CID reproduced, content matched, metadata regenerated, 41 fork tests and 17 CLI scenarios pass

AUD-01: Pre-migration Aragon proposals retain execution authority

Severity: High | **Disposition:** ACK, risk accepted
Code status: Unchanged
Affected: governance-transition calls in `src/MigrationScript.sol`
Requirement: GOV-2 | **First reviewed revision:** `0e10333`

Description. Raising each voting app's support and quorum changes defaults for subsequent proposals. The existing voting implementation stores support and quorum inside each proposal when it is created. Votes created earlier continue using those stored values. Removing permission to create new proposals does not prevent support or execution of an existing proposal.

The migration also leaves the voting apps' Agent execution, script-running, and transfer permissions in place. The primary voting app remains the manager of important Agent roles and retains script-registry permissions. Removing only the Kernel and ACL root roles does not remove these existing authorities or their surviving managers.

Observed effect. A local fork test creates a second Aragon proposal before executing the migration. The migration succeeds and blocks new Aragon proposal creation. The second proposal receives sufficient support afterward and changes the pool's unstake waiting period through the primary Agent. The test uses valid governance approvals and synthetic local state. It does not establish that such a competing proposal exists on mainnet. This finding concerns Aragon proposal execution. Staking-based voting power is intended to continue in Snapshot.

Conditions and impact. An Aragon proposal must have been created before migration and must obtain the support required by its own stored thresholds. The completed review includes approved but unexecuted proposals. Surviving Agent authority extends beyond the demonstrated parameter setter to pool administration, management of existing permissions, and script-registry administration.

Acknowledgment and completed review. The proposal author confirms that all outstanding primary and secondary proposals, including approved but unexecuted votes, have been reviewed. No unrelated existing proposal can affect the migration outcome. Designated token-transfer secondaries 133 and 134 are intentional parts of the migration. The accepted residual risk is a new competing proposal created before primary execution. If one appears, the author will urge its rejection. The surviving contract authority remains unchanged.

Acceptance rationale. The author prefers lower call count and calldata complexity over further permission-removal operations. This acceptance covers primary and secondary Aragon proposals. The revised plan explicitly includes designated PNK and wPOKT votes 133 and 134. Their execution after migration remains possible and was retested.

Technical remediation option. If technical elimination is later desired, remove the relevant Agent execution, script-running, transfer, and script-registry authorities and their restoration paths after the migration's last privileged call. Include both voting apps, surviving permission managers, and the primary Agent's newly granted secondary-Agent permissions. Preserve all intended pool user actions.

Retest if technically remediated. Test primary and secondary Aragon proposals created before migration, including already approved proposals. Confirm they cannot exercise the retired authorities or restore them, while pool user actions continue to work. No such fix is claimed for this accepted finding.

Evidence. `test_AUD01_PreMigrationVoteCanChangePoolSettingsAfterMigration` and `test_AUD01_AgentAndRegistryPermissionsAndManagersRemain` in the audit test harness. Reference sources include the deployed voting implementation's `_newVote`, `_canExecute`, and `vote` behavior, the Agent interfaces, and the ACL permission-manager model. Completion and outcome of the outstanding-proposal review are recorded on the proposal author's confirmation.

AUD-02: Primary execution depended on PNK and wPOKT transfers

Severity: Medium | **Disposition:** Mitigated
Code status: PNK and wPOKT removed from primary
Mitigation scope: PNK/wPOKT reads and transfers removed from primary
Requirement: AST-1 | **First reviewed revision:** `0e10333`

Description and original scope. PNK controller restrictions or wPOKT pausing could block the original primary. The initial report grouped this with fixed amounts under "Fixed treasury amounts can fail execution or leave assets behind". That history is retained. The final Mitigated disposition applies to removal of the PNK/wPOKT dependency.

Original observations. On a local fork, a later one-API3 deposit remains after successful execution. An authorized one-base-unit USDC reduction causes atomic rollback of the primary, preserving token ownership, pool minting, and proposal permissions. These fixed-amount observations remain part of the history and operating assumptions.

Impact before mitigation. Either token refusing its transfer could revert the complete primary. Additional deposits instead leave residuals and do not block fixed transfers. Removing all old authority under AUD-01 could make residuals inaccessible without an intentional recovery path.

Original acknowledgment. The author accepted fixed-amount treasury risk and initially retained a single primary. The reviewed mitigation supersedes inclusion of PNK and wPOKT in that primary. Fixed-amount asset handling and residual donations remain accepted design conditions.

Expanded ACK. The author accepted external transfer restrictions and residual donations. PNK controller restrictions and wPOKT pausing could block the original primary despite sufficient balances. They now affect the corresponding secondary transfer. A dynamic balance helper cannot override those restrictions. Recipient assets remain under Safe control.

Mitigation and retest. Commit `c6d977f`, merged as `a920489`, removes both token constants, balance reads, positive-balance requirements, and transfers. Amount output and baseline assertions are updated. The 26-call primary is 4,316 bytes. Remaining calls, recipients, and privileges are unchanged apart from renumbering. Secondaries 133 and 134 carry the removed transfers. Nine checks validate their exact payloads, all six execution orders, generation after emptying both tokens, primary-only balance preservation, and primary success with both token contracts reverting. All 49 tests passed at `4740c29`. The current 41-test suite passes at both review blocks, including the unchanged nine mitigation checks.

Accepted operating assumptions. API3, USDC, and ETH amounts remain fixed. Later deposits may remain and do not block execution, as accepted by the author. Sufficient balances and USDC transfer availability remain execution preconditions. Each secondary retains its token-policy dependency. The original Medium severity is historical. The primary's PNK/wPOKT dependency is mitigated.

Recommended operating checks. Recheck balances before posting and execution. Address shortfalls or approve a replacement before new proposals are disabled. Report residual assets. Review recipient restrictions and retained authority if a later design adds dynamic sweeping or recovery.

Future design changes. Changes to dynamic sweeping or recovery require tests of increases, decreases, zero and unchanged balances, atomic rollback, recipient restrictions, and retained authority. Rebuild and compare the final call table after any payload change.

Evidence. The original `test_AUD02_DonationAfterBuildingLeavesResidualTreasuryBalance` and `test_AUD02_BalanceReductionBeforeExecutionRevertsEntireMigration` remain unchanged and pass against the revised primary. Nine new scenarios in `SecondaryMigration.t.sol` validate the mitigation using the actual posted scripts. Baseline assertions cover the unchanged-balance case, and the existing zero-USDC test confirms generation rejects one zero-balance case.

AUD-03: Snapshot reconstruction can reject an unchanged payload

Severity: Medium, original | **Disposition:** Mitigated
Code status: Explicit build-block fallback implemented
Affected: `script/VerifyVote.s.sol`, generation provenance
Requirement: VER-1 | **First reviewed revision:** `0e10333`
Mitigation: `7b14436`, merged as `4740c29`

Original finding. Generation reads amounts at the build block, while the original verifier reconstructed only at the proposal's snapshot block. A relevant balance or supply change could therefore reject an unchanged, correctly generated payload. Different block numbers alone do not imply different payloads. The initial generation/snapshot observation tests and the author's acknowledgment remain part of the history.

Mitigation. The new overload, `run(voteId, buildBlock)`, keeps snapshot reconstruction as its first check. If that differs, it requires the supplied build block to be no later than the snapshot, rebuilds at that block, and compares the complete script hash. It reports changes to the mint, primary Agent API3, secondary USDC, and secondary ETH amounts. Creator and metadata checks remain in place. The original one-argument form remains available and instructs the operator to use the overload when amounts differ.

CLI retest. The actual Forge verifier was rerun with the final title and IPFS metadata against synthetic votes posted on a private Anvil fork of the original reference block. Local posting uses `castVote=true` and `executesIfDecided=false`. Seventeen scenarios pass their expected assertions. Unchanged same-snapshot and delayed votes verify. Explicit build-block verification succeeds after ETH and USDC changes, a primary Agent API3 change, a holder burn, and a reward mint. Altered script bytes, altered metadata, an incorrect creator, a nonexistent vote, and zero build block are rejected. On the fallback path, a future block is rejected, as is a block whose reconstructed script differs from the posted script. The legacy form correctly rejects the drift case and requests the new overload. These are local simulations, not verification of the final mainnet primary.

Retained limits. The argument is a fallback hint, not an unconditional provenance pin. When snapshot bytes already match, the supplied positive build block is not consulted. A tested future hint is therefore ignored on that path. The verifier also calls `readAmounts()` at the snapshot before trying fallback. Its positive-balance and supply guards still apply. A tested zero-USDC snapshot rejects verification before the otherwise valid build reference can be used. The earlier payload can remain authentic despite this rejection. Investigate the snapshot guard and execution preconditions separately.

Different historical blocks can reproduce identical amounts and script bytes. Such a block can satisfy fallback verification even if generation occurred elsewhere. Acceptance establishes a matching historical state, not proof of the actual generation block.

Operating requirement. Retain the approved generation block number and hash, source revision, script hash, amounts, and exact metadata. The overload does not authenticate the supplied block against an approval record or take an expected block hash. Keep the voting snapshot as the reference for voting power and creation-event lookup. Independently recheck execution state and investigate any guard failure. The actual posted primary must still be matched to the approved release bundle after posting.

Disposition. The source change mitigates the original false-rejection problem for relevant drift while snapshot generation preconditions hold. The remaining guards and provenance duties above are explicit limits of that conclusion. No execution call or asset amount calculation was changed by this verifier update.

Evidence. The original `MigrationAudit.t.sol` observations remain unchanged. `test_verify_vote.py` invokes the unmodified production verifier CLI, checks real local creation logs, and records all 17 results. The local fork uses chain ID 31337 and immutable storage cached at the matching Ethereum reference to avoid repeated archive reads. No mainnet transaction was signed or broadcast.

AUD-04: The proposal description was a placeholder

Severity: Low, original | **Disposition:** Resolved
Reviewed state: Final title and IPFS description committed and reviewed
Affected: `proposal/title.txt` and `proposal/description.md`
Requirement: META-1 | **First reviewed revision:** `0e10333`
Resolution: `5bff6fc`, merged as `c7a7d26`

Original finding. The description was `TODO: IPFS link`. Generation and structural metadata tests accepted it as nonempty content. This did not communicate the migration intent or identify final voter-facing text. The original acknowledgment and release requirement remain in the finding history.

Resolution. The committed title is **200,000,000 API3**. The description now identifies the final 29-page proposal PDF through its immutable IPFS CID. The PDF was downloaded from the exact committed gateway URL. Kubo 0.43.1 reproduced the CID using the downloaded bytes, CID version 1, and the default UnixFS importer. The document SHA-256 is recorded in Appendix B.

The review compared the migration provisions in sections 3, 6, 11 and 12 and Appendices A and B with all 26 generated calls. They describe the Treasury and Agent recipients, the fixed mint formula, retirement of minting, token ownership destination, legacy vote-creation and root-permission changes, continued pool actions, holder-burn effects, fixed-balance drift, and operator overshoot cleanup. The surviving authority of previously created proposals is expressly qualified in Appendix A and remains accepted under AUD-01.

The document displays rounded supply and mint figures. Exact amounts are determined by the source at the generation block. Appendix B of this report records their full base-unit integers. Snapshot settings, delegation, Safe operations, the charter, and business commitments in the proposal remain external dependencies or author-supplied context under section 2.

Retest. Generation produces exactly three metadata fields separated by two `0x1f` delimiters: version `3`, the final title, and the committed IPFS URL. The exact 130 metadata bytes and their hash are retained. Metadata and serialization assertions pass in the 41-test suite at both reference blocks. The production verifier accepts the final metadata and rejects altered metadata in the 17-scenario local CLI rehearsal.

Disposition and limits. The placeholder is resolved for this reviewed release. No generic future-placeholder rejection is claimed. At the final reference block the primary voting app contained 17 historical votes, IDs 0 through 16. The migration primary had not been posted, so its eventual StartVote event, creator, metadata, and script must still be compared with the approved generation bundle. Later content or URL changes require a focused re-review.

Evidence. The committed proposal files, authenticated primary-description PDF, content hashes, generated metadata, repository metadata tests, and production verifier CLI results support this resolution. Source and supplemental evidence are retained separately from this published PDF.

5. Validation and coverage

Methodology

The review follows the source-generated payload through its callers, nested Agent calls, token operations, permission changes, and post-migration pool interfaces. Deployed dependency sources were obtained from public explorers and checked against the required interface behavior. Read-only reference calls identify the implementation addresses and relevant preconditions at the frozen block.

The combined suite includes the 20 repository tests and 21 retained supplemental audit tests. Additional tests use a local Ethereum fork, legitimate holder voting power, and controlled local changes that represent plausible migration timing and integration conditions. Impersonating holders and Safes verifies contract behavior under those callers. It does not verify signatures, signer availability, Safe transaction construction, or an operator's future actions.

Supplemental audit tests and logs are retained separately and are not included in this published PDF.

Reference evidence includes block and code hashes, source-file hashes, minter and claims-manager event histories, ACL grants and managers, Safe owner lists and thresholds, token balances, and pool configuration. The refreshed reference RPC capture returned the same one historical minter-status event, enabling the staking pool, and no historical claims-manager-status events through block 26,296,196. No new ACL permission or manager events appeared since the original reference. These are reference-state observations, not guarantees about later state.

Validation results

Check	Result and significance
Foundry compilation	Pass with Solidity 0.8.20. Existing linter warnings remain documented below
`forge fmt --check`	Pass
`bulloak check test/*/*.tree`	Pass for the repository's existing branching-tree specifications
Current repository tests	20 pass as part of the combined suite at both reference blocks
Original added audit and compatibility checks	12 passed, 0 failed, 0 skipped against the revised implementation
Secondary-split remediation checks	9 passed, 0 failed, 0 skipped, including all six execution orders
Complete review suite	41 passed, 0 failed, 0 skipped at blocks 26,287,968 and 26,296,196 against c7a7d26
Production verifier CLI integration	17 local scenarios pass with the final metadata, `castVote=true`, and `executesIfDecided=false`. Documented snapshot-guard and fallback-hint limits retained
README call table regeneration	Unchanged at reference block 26,287,968
Reference network check	Chain ID 1 confirmed. All 15 dependency runtime hashes, proxy implementations, Safe owner sets, thresholds, and queried first module pages match the original capture

The original-block script and README table reproduce exactly. At the final block only the encoded mint changes, reflecting the weekly reward. The final document CID and metadata are authenticated under AUD-04. CLI votes use local chain 31337 and anchored cached storage. Both real secondary payloads and metadata still match their original captures. No mainnet approval, execution, or signer authorization is inferred.

User-action coverage

Behavior	Evidence and limits
Pool balances, total stake, shares, sample user stake and locked rewards	Added before/after accounting assertions
Existing staker full exit and reward vesting	Baseline tests cover seven-day waiting, lock limits, 26-epoch reduction, and full reward unlock after the vesting window
Partial exit, re-entry, and later full exit	Baseline scenario spans more than a year
New deposits and staking	Baseline and added scenarios cover `depositRegular`, `stake`, and `depositAndStake`
Pending unstake created before migration	Added test completes it after migration and withdraws unlocked funds
Separate and combined exits	Baseline `unstake` and `withdrawRegular`, added `unstakeAndWithdraw`
Delegation and undelegation	Added test updates delegation, respects the cooldown, and completes an exit
Expensive-lock withdrawal alternative	Added test completes `precalculateUserLocked` in chunks and uses `withdrawPrecalculated` for an existing staker
Pool-side vesting integration	Added test calls `deposit`, `depositWithVesting`, and `updateTimelockStatus` as the existing manager. The manager implementation and real manager transactions are excluded
Reward cessation	Baseline calls advance epochs without minting and preserve stake. Added compatibility flows retain the expected total supply
Proposal creation	Four-argument creation is covered by the baseline. Added checks cover the two-argument overload and forwarding on both apps

Material limitations and existing warnings

The added audit harness supplements the existing branching-tree specifications. The report does not claim formal verification, exhaustive path coverage, or a full end-to-end Safe-signature rehearsal.

The baseline linter reports a narrowing cast for CallsScript length and warnings about block/time reads around Foundry time travel. The reviewed script has bounded, fixed call sizes far below the 32-bit length limit. The time-travel warnings concern test methodology and were not suppressed. No production fix or test weakening was made to obtain passing checks.

Tests use representative accounts and synthetic local states. They do not prove behavior for every historical user's checkpoint layout, every possible future state, or every third-party token policy. Some existing integration tests exercise a single qualifying staker chosen from the fixture. No claim of complete user-state enumeration is made.

This completed assessment applies to the identified source revision and reference state. It does not establish exhaustive defect detection. The final committed proposal metadata is covered by this assessment. The eventual posted primary, later source or metadata revisions, and execution-time state require the checks specified in section 7 and Appendix C.

6. Assumptions and acknowledgments

Acknowledgment means the proposal author accepts a stated dependency and its effect. It does not turn an external system into audited code or mark an unmet mandatory criterion as passing.

ID	Assumption or operating dependency	Status
A-01	200M API3 is a target subject to holder burns and overshoot cleanup, rather than an exact atomic invariant in every state	Acknowledged by the proposal author
A-02	The three recipient/proposer Safe addresses are the intended operational wallets, and the required owners remain available to act	Address configuration observed at reference block. Confirm custody intent and operator availability before posting
A-03	If rewards increase supply after generation, a DAO Safe will opt into burning, burn the calculated excess, and opt out afterward. It must retain enough API3 to do so	Cleanup principle retained. The Treasury Safe represents this action in passing fork tests. Confirm the actual responsible Safe and available balance before execution
A-04	Snapshot governance is configured and ready, with the intended voting strategies, proposer authority, delegations, and treatment of treasury voting weight	External operational dependency. Confirm the release configuration and record its reference
A-05	The generation, posting, and execution references are authenticated and relevant state is rechecked before execution	Use the build-block overload when reconstruction differs under AUD-03. Retain authenticated generation records. Fixed amounts and residual donations are accepted design conditions
A-06	Existing TimelockManager-side operations remain available where needed. The migration does not change its pool-side integration permissions	Pool-side compatibility tested. Manager-side implementation and end-to-end operation are external dependencies
A-07	No party controls the dead-address token owner, and no unexpected active minter is introduced between reference capture and execution	Standard ownership-retirement assumption, supported only for the captured known minter state. Final preflight required
A-08	Secondary votes 133 and 134 are intended to transfer their respective tokens. Any later sale for USDC is an Agent Safe operator action	Execution order is flexible. All six orders pass local fork tests. Loss of the retry option after primary execution is accepted. Token-sale execution and proceeds are outside this assessment

Reference observations about Safe custody

At the reference block, the Vault, Treasury, and Agent Safes report the same set of five owners and a threshold of three. The queried first module page is empty for each Safe. These checks support the stated recipient configuration. They do not establish who controls the owner keys, guarantee owner availability, or constitute a full Safe configuration audit. Guards and fallback handlers were not exhaustively reviewed.

The Treasury Safe is deployed and has zero API3 before migration at the reference block. Its burner status is false. The token permits an address to opt into burning independently of token ownership, and the fallback fork scenario succeeds with opt-in after migration, burning the overshoot, and opt-out afterward. A real cleanup burn remains a separate operator action.

7. Execution requirements

Operating controls

1. The outstanding-proposal review under AUD-01 is complete. No unrelated existing proposal can affect the migration outcome. Designated secondaries 133 and 134 remain intentional migration transfers. Any new unrelated proposal before primary execution falls under the accepted governance-process risk.
2. Check actual balances and transfer availability for primary API3, USDC, and ETH, and separately for the PNK and wPOKT secondary transfers. Execution order is flexible, with the accepted retry risk described in section 3. Record receipts for all three votes and any shortfall, residual balance, or token restriction and the operating response.
3. Under AUD-03, retain the generation block and hash, source revision, script hash, and exact metadata. Use `run(voteId, buildBlock)` when snapshot reconstruction differs. The block argument is a fallback hint, so provenance authentication and investigation of snapshot guard failures remain separate duties.
4. AUD-04 is resolved for the final title and authenticated IPFS document in Appendix B. Preserve those exact metadata bytes and re-review any later change before posting.
5. Confirm the external operating dependencies in section 6, including Snapshot configuration, Safe operators, cleanup responsibility, and the TimelockManager boundary.
6. Preserve the approved source and artifact bundle. Review later source or metadata changes and rerun the affected checks and full suite under Appendix C before reusing the report's conclusion.

Before proposal submission

1. Confirm chain ID, generation block hash, contract implementations, token ownership, complete current minter set, required ACL permissions, and the Vault's ability to propose at the actual snapshot. The seven-day proposer cooldown is shared across both voting apps. Keep the primary proposer eligible for submission.
2. Confirm all listed balances and recipient addresses under the adopted drift policy. Check that the Treasury Safe can receive the assets and perform any required cleanup.
3. Approve the exact CallsScript bytes and hash, metadata bytes and hash, source revision, amounts, and intended `newVote` arguments. `CreateVote` currently emits the script and metadata separately rather than a fully encoded `newVote` transaction.
4. Ensure proposal submission uses the approved payload. This review does not authorize a signature or a broadcast.

After posting and before execution

1. Match the posted script, metadata event, creator, and generation provenance to the approved bundle using the generation-block verification procedure required by AUD-03.
2. Recheck balance and supply drift, minters, external token conditions relevant to transfer success, any newly created unrelated legacy proposals, and all execution preconditions.
3. Simulate the exact posted payload against a fresh reference block using the final acceptance criteria and adopted operating constraints.
4. Confirm the cleanup owner and procedure if the supply will exceed the target. Any required mainnet action needs a separate explicit authorization.

After execution

Verify recipient credits and receipts for all three votes, residual Agent balances, token ownership, the full minter set, disabled new proposal creation, and pool accounting. Record remaining Aragon authority under AUD-01. Retain proposal IDs, transaction and block hashes, any separately authorized cleanup burn and resulting supply, and the final Snapshot configuration reference.

Appendix A. Address and implementation reference

Etherscan links identify the referenced contract addresses. Proxy implementation addresses are read at the frozen block. Explorer labels alone are not used as proof of identity.

Dependency	Address
API3 token	`0x0b38210ea11411557c13457d4da7dc6ea731b88a`
Staking pool	`0x6dd655f10d4b9e242ae186d9050b68f725c76d76`
Primary voting app	`0xdb6c812e439ce5c740570578681ea7aadba5170b`
Secondary voting app	`0x1c8058e72e4902b3431ef057e8d9a58a73f26372`
Primary Agent	`0xd9f80bdb37e6bad114d747e60ce6d2aaf26704ae`
Secondary Agent	`0x556ecbb0311d350491ba0ec7e019c354d7723ce0`
ACL	`0x1e7ecc6d3b5b4cfdfc71cb7c3ea9ac4a55f4195a`
Kernel	`0x593ea926ee9820a933488b6a288433c387d06dba`
Script registry	`0x3d9aa440ecbbf7927200610cdd79a5a7c2388aad`
Vault Safe	`0x8e03609ed680b237c7b6f8020472ca0687308b24`
Treasury Safe	`0xb7fa2cb302c5dc127e61f27b92bec411cbf0ae4a`
Agent Safe	`0xbbe0de9757f93e3306adbfebe906ab285edd13da`
USDC	`0xa0b86991c6218b36c1d19d4a2e9eb0ce3606eb48`
PNK	`0x93ed3fbe21207ec2e8f2d3c3de6e058cb73bc04d`
wPOKT	`0x67f4c72a50f8df6487720261e188f2abe83f57d7`
Token ownership destination	`0x000000000000000000000000000000000000dead`

Both voting apps use implementation `0xc215c66b455e9f7854e7870631f2a01878b0521a`. Both Agents use `0x3a93c17fc82cc33420d1809dda9fb715cc89dd37`. The ACL implementation is `0x81f7564e413586f1f99fde55740ac52b43ca99c9`. The Kernel implementation is `0x2b33cf282f867a7ff693a66e11b0fcc5552e4425`.

Primary source references

- API3 token explorer source.
- Staking pool explorer source.
- Voting implementation source.
- Agent implementation source.
- ACL implementation source.
- Kernel implementation source.

Explorer source pages do not constitute independent assurance. The recorded code hashes and proxy implementation reads identify the reviewed deployment state. Safe configuration observations are limited to the checks described in section 6.

Appendix B. Frozen payload and evidence provenance

Review anchor

Item	Value
Source revision	`c7a7d26c705f703ff50b80e8f976ab3dcdee1372`
Final reference block	26,296,196
Final reference block hash	`0x6b63fd0357681139f977051e3e066e6b4d336f3d67aa9ac6dc480365d38917b6`
Final reference block time	29 October 2026, 05:06:23 UTC
CallsScript length	4,316 bytes
Number of calls	26
Final-reference script keccak256	`0xd43e2dfeaea2e20c47dedf08405bc3483218dabd87643a0b9ddf3df5a390cf64`
Original regression block	26,287,968
Original block hash	`0xcca45235fa8658249b3ad57c038bb158350f9123801d353e417572f2c723248d`
Reproduced original script keccak256	`0xd5b3d6e60f527d3cc660f00a2b4e90779eb1d69b790c60e992b452b34ef924ae`
Foundry	Forge and Cast 1.8.5
Solidity compiler	0.8.20
Forge standard library	Setup pins tag v1.17.0
Branching-tree checker	bulloak 0.8.1

Each script hash identifies execution bytes generated at its stated block. It does not bind a later generation state or metadata. The original hash is reproduced byte for byte by the final source. The final-reference mint reflects the weekly reward already minted, rather than a change to migration logic.

Amounts encoded at the reference block

Amount	Integer base units
API3 minted to Treasury Safe	`992900026576196988740038 4`
Primary Agent API3 to Treasury Safe	`6083873527701856751553400`
Secondary Agent USDC to Agent Safe	`59419713966`
Secondary Agent ETH to Agent Safe	`57118793443618210` wei

Final metadata and immutable content

The title is **200,000,000 API3**. The description is the exact final proposal PDF URL committed in `proposal/description.md`. The CID is `bafybeice2nz5rvwnmutwbjnulbzajc6mboqr7e426g6rwj5dnb2t7l4v3e`. Kubo's read-only importer reproduced it from the downloaded 1,243,410-byte, 29-page PDF.

Artifact	Hash
Proposal PDF SHA-256	`d5a53a271f86e3c14f906d0c1a6ee6a855120ffd7f430a9222493e8546c7e476`
Exact metadata keccak256, 130 bytes	`0xe9071106e7e0c5acc1c9e47d8e9f8e572414e6c633a4307d0318deb89f811ee9`

Monetary amounts in `amounts.json` are exact decimal strings. The block is a JSON integer. The source-generated base-unit values above are authoritative for this reference payload. The proposal's displayed 190,071,000 supply and 9,929,000 mint are rounded summaries of 190,070,999.734238030112599616 and 9,929,000.265761969887400384 API3. Actual posting must retain its own approved generation block, hash, and full-precision payload.

Appendix C. Review validity and subsequent revisions

This is the completed version 1.5 assessment of source revision `c7a7d26c705f703ff50b80e8f976ab3dcdee1372`, issued on 29 October 2026. Version 1.0 assessed `0e10333` with a 28-call primary. Version 1.1 assessed `a920489`, its 26-call primary, posted secondaries, and the mitigation of AUD-02. Version 1.2 reviewed the verification change merged as `4740c29` and the tested build-block fallback under AUD-03. Versions 1.3 and 1.4 clarified execution order, accepted secondary retry risk, verifier limits, public references, and the completed outstanding-proposal review.

Version 1.5 reviews the final title and IPFS document committed by `8e58d29` and `5bff6fc`, merged as `c7a7d26`, and resolves AUD-04. It also reviews all intervening source and documentation changes, including exact monetary serialization, duplicated-test removal, and post-burn opt-out. The migration and verifier logic are unchanged. All 41 current fork tests pass at the original and final blocks, and 17 production CLI scenarios pass with final metadata. Dependency hashes and authority history remain consistent with the original capture. The new reference mint accounts for the weekly reward already minted. Original finding IDs, severities, prior dispositions, acknowledgments, and historical test results remain recorded. AUD-01 remains accepted, AUD-02 and AUD-03 remain mitigated, and no new finding was confirmed.

Each finding retains its original ID, affected revision, severity, evidence, and acknowledgment. A later remediation adds its exact commit, changed behavior, targeted regression result, and full-suite result. The original observation tests remain evidence for the reviewed revision. Accepted risks and operating requirements are separate from technical fixes.

For a newer branch, identify its exact commit and compare every in-scope change with this report's revision. Review the changed call sequence, asset list, recipients, permissions, supply calculation, generation and verification logic, and metadata as applicable. Run the target revision's static checks and full tests, reassess the recorded findings, and repeat relevant fork scenarios against an identified block and hash. Passing tests alone does not extend this report to the new revision.

Issue a versioned update identifying the new source revision, reference block, artifact hashes, material changes, test results, and finding dispositions. If an acceptance changes, retain the original record and add the superseding decision and rationale. The report applies to its stated revision until such an update is completed. Final proposal preparation and posted-vote verification remain subject to section 7.